

(b) Guía metodológica detallada de la encuesta MITRE D3FEND

1. Propósito de la encuesta

La encuesta tiene como objetivo principal medir el grado de adopción, madurez y efectividad del enfoque de defensa informada por amenazas basado en MITRE ATT&CK y MITRE D3FEND, incluyendo el uso de D3FEND CAD y la incorporación de métricas operativas y de negocio.[web:1][web:5][web:19]

Se dirige a organizaciones que operan servicios esenciales o importantes bajo el paraguas regulatorio europeo (NIS2) y nacional, así como a entidades que, aun sin obligación directa, han decidido tomarse la seguridad en serio por convicción, trauma o ambas cosas a la vez.[web:25][web:26][web:27]

2. Enfoque conceptual

La encuesta se apoya en tres pilares conceptuales:

1. Ontología de contramedidas (MITRE D3FEND): entendida como un vocabulario estructurado de técnicas defensivas, artefactos, sensores, vulnerabilidades y relaciones, que permite razonar sobre coberturas, lagunas y profundidad de defensa.[web:1][web:2]
2. Lenguaje común de amenazas (MITRE ATT&CK): utilizado para describir técnicas y tácticas de adversarios, que sirve de referencia para definir catálogos de amenazas prioritarias.[web:3][web:8]
3. Métricas operativas y de negocio: derivadas de la práctica profesional (latencia de detección, eficacia de mitigaciones, cobertura de telemetría, etc.) y conectadas con indicadores de riesgo y retorno de inversión.[web:5][web:18][web:21]

La encuesta explora cómo estos tres elementos se articulan en la práctica de las organizaciones.

3. Estructura de la encuesta

La encuesta está organizada en bloques temáticos que siguen una progresión lógica:

- Datos generales de la organización y del respondente.
- Conocimiento y adopción de MITRE D3FEND y ATT&CK.
- Uso de D3FEND CAD y modelado de grafos de contramedidas.[web:19][web:22]
- Indicadores de cobertura ATT&CK–D3FEND.
- Métricas operativas (latencia, eficacia, telemetría).
- Entornos OT / ICS y extensión D3FEND para OT.[web:5]
- Integración con el cumplimiento normativo (NIS2, legislación nacional, marcos de control).
- Métricas de negocio, indicadores de madurez global (IGM) y ROI.
- Gobierno, cultura y talento.
- Perspectiva y próximos pasos.

Esta estructura permite analizar tanto el nivel de adopción técnica como el grado de institucionalización en la gobernanza y el negocio.

4. Población objetivo y segmentación

La población objetivo incluye:

- Operadores de servicios esenciales y entidades importantes según NIS2 y su transposición nacional. [web:25][web:26][web:27]
- Organizaciones públicas y privadas que, aun fuera de NIS2, tienen una exposición significativa a la amenaza (por tamaño, criticidad o interdependencias).

Para el análisis de resultados se recomienda segmentar al menos por:

- Sector (energía, salud, financiero, etc.).
- Tamaño de la organización.
- Ámbito geográfico de operación.
- Grado de exposición OT / ICS.

5. Escalas de respuesta y tratamiento de datos

La encuesta combina preguntas de elección única, múltiple y de respuesta abierta.

Las escalas ordinales (por ejemplo, niveles de cobertura, frecuencia, madurez) se utilizarán para construir índices compuestos como el Índice Global de Madurez (IGM), descrito en la plantilla de Excel. [web:18][web:21]

Se recomienda codificar las respuestas de forma numérica para facilitar el análisis estadístico y la comparación entre organizaciones y sectores. Por ejemplo:

- Escala de conocimiento/adopción (0–4).
- Escala de cobertura (0–4).
- Escala de madurez de métricas (0–3).

6. Indicadores derivados

A partir de las respuestas se pueden derivar, entre otros, los siguientes indicadores:

- Porcentaje de organizaciones que utilizan D3FEND explícitamente para describir controles.[web:1][web:14]
- Nivel medio de cobertura de técnicas ATT&CK críticas.[web:3][web:8]
- Proporción de organizaciones que miden MTTD y MTTR de forma sistemática.[web:18][web:21]
- Nivel de adopción de métricas de telemetría y calidad de detección.[web:5][web:19]
- Grado de integración con el cumplimiento normativo (existencia de mapeos formales).[web:5][web:25][web:26]
- Grado de utilización de métricas para justificar inversiones (ROI) y medir el IGM.[web:5][web:18][web:21]

Estos indicadores permiten comparar sectores, tamaños de organización y países, así como seguir la evolución temporal.

7. Consideraciones éticas y de confidencialidad

Dado que la encuesta puede revelar información sensible sobre capacidades defensivas, se recomienda:

- Anonimizar los resultados antes de cualquier análisis agregado.
- Evitar la identificación directa de organizaciones en reportes públicos sin su consentimiento explícito.
- Comunicar claramente el uso previsto de los datos y las medidas de protección aplicadas.

8. Limitaciones

La encuesta describe percepción y autoevaluación; por tanto, está sujeta a sesgos de optimismo, de deseabilidad social y de memoria selectiva, especialmente después de incidentes traumáticos.

No sustituye a auditorías técnicas, ejercicios de red teaming o análisis forense, pero sí ofrece un mapa de cómo las organizaciones se ven a sí mismas frente a un estándar exigente.[web:5][web:14]

9. Uso recomendado

Se sugiere utilizar la encuesta:

- Como diagnóstico inicial para programas sectoriales o nacionales de mejora de capacidades defensivas.
- Como instrumento periódico (por ejemplo, anual) para medir progreso y orientar políticas públicas.
- Como base para talleres con organizaciones, contrastando la autoevaluación con ejemplos prácticos de modelado D3FEND CAD.[web:19][web:29]

En manos de un regulador o de un consorcio sectorial, la encuesta puede convertirse en un mecanismo suave pero insistente para mover la conversación de "cumplimos" a "sabemos exactamente qué ataques podemos resistir y cuáles no".